

BEFORE Placeholder

AFTER

Incident-Triggered Supplier Review Playbook

Document classification: Internal

Document owner: Third-Party Security Program Owner

Version: 0.1

Effective date: _____

Review cadence (this document): Annually

1. Purpose

This playbook defines the actions required when a supplier reports (or is credibly suspected of having) a security incident that may affect the organisation's data, systems, or critical services.

2. When to use this playbook

Use this playbook when any of the following occur:

- Supplier notifies a security incident/breach impacting the service scope.
- Credible intelligence suggests supplier compromise relevant to the service.
- Internal monitoring indicates suspicious supplier activity (e.g., anomalous logins, unusual API calls).
- Supplier fails to meet incident notification commitments.

3. Objectives

- Rapidly determine organisational impact (data/access/service).
- Apply containment actions to reduce exposure.

- Ensure timely notification, governance escalation, and evidence capture.
- Reassess supplier controls and decide: continue, restrict, or offboard.
- Ensure exceptions/conditions are updated and tracked to closure.

4. Roles (generic)

- **Security Incident Lead** (internal): owns incident coordination and technical triage.
- **Third-Party Security Program Owner**: owns supplier assurance actions, decisions, and records.
- **Security Engineering/Architecture**: assesses control gaps and required remediations.
- **IT/Platform Owner**: executes containment actions (access disablement, key rotation, connectivity changes).
- **Business Service Owner**: validates business impact, workaround options, and endorses decisions.
- **DPO/Privacy Officer**: leads privacy breach assessment and regulatory/customer notification guidance (where personal data is involved).
- **Legal Counsel**: supports legal obligations, contractual enforcement, and external communications constraints.
- **Procurement**: manages supplier engagement and contractual levers.
- **Senior Residual Risk Acceptor**: approves material residual risk decisions for Critical suppliers per governance.

5. Severity classification (supplier incidents)

Severity 1 — Confirmed/highly likely impact

Indicators:

- confirmed compromise of in-scope data
- confirmed unauthorised access to organisational tenant/environment
- ransomware/outage affecting critical business service
- supplier admits material control failure affecting confidentiality/integrity/availability

Severity 2 — Potential/limited impact

Indicators:

- incident in supplier environment with uncertain impact to our tenancy/data
- suspicious supplier account activity requiring investigation
- partial outage or limited data exposure

Severity 3 — Advisory / near miss

Indicators:

- supplier incident not impacting our service scope, but relevant to shared components/sub-processors
- vulnerability disclosure with mitigation available and no evidence of exploitation

6. Response timelines (minimum)

- Severity 1: initiate within **2 business hours** (or as soon as detected), convene stakeholders same day.
- Severity 2: initiate within **1 business day**.
- Severity 3: initiate within **5 business days** (unless escalated by risk context).

7. Playbook steps

Step 1 — Intake and record creation

Owner: Third-Party Security Program Owner

Actions:

- Create an incident-triggered review record (supplier, service, tier, timestamp).
- Capture initial notification details verbatim (email/ticket reference).
- Confirm supplier incident contact and establish communication channel. Outputs:
- Review record opened; stakeholder notifications sent.

Step 2 — Immediate triage (scope and exposure)

Owner: Security Incident Lead + SEA + IT/Platform Owner

Actions (minimum):

- Confirm supplier tier and integration profile:
 - SSO/API/agent/connectivity
 - privileged access paths
 - data types and residency
- Determine initial exposure hypotheses:
 - could organisational data be accessed/exfiltrated?
 - could supplier credentials/tokens be compromised?
 - could service integrity be impacted (tampering/deployment)?
 - is there an availability impact to critical services? Outputs:
- Initial impact statement (what we know / don't know).
- Severity assigned (1/2/3).

Step 3 — Containment (protective actions)

Owner: IT/Platform Owner (execution) + Security Incident Lead (direction)

Select and execute appropriate actions (as applicable): Identity & access:

- ☐ Disable supplier user accounts / revoke admin roles
- ☐ Disable SSO app / tighten conditional access
- ☐ Revoke/rotate API keys, tokens, certificates; rotate shared secrets Connectivity:
- ☐ Suspend VPN/private link / restrict firewall rules
- ☐ Block inbound connectivity and remote support tooling access Integrations:
- ☐ Disable API write capabilities / reduce scopes
- ☐ Pause automation and scheduled jobs reliant on supplier tokens Monitoring:
- ☐ Increase logging/alerting for supplier-related activity Outputs:
- Containment actions log with timestamps and evidence.

Step 4 — Supplier information request (focused)

Owner: SEA + Procurement + Legal Counsel (as needed)

Request (minimum):

- incident summary, start time, detection method
- affected systems and whether our tenancy/data was implicated
- indicators of compromise (IOCs) relevant to customer environments
- actions taken (containment, eradication, recovery)
- confirmation of data types impacted (if any) and preliminary impact assessment
- timeline for next update and final RCA
- sub-processor involvement (if any) Outputs:
- Supplier response captured; gaps in information recorded and chased.

Step 5 — Privacy and regulatory assessment (if personal data)

Owner: DPO/Privacy Officer

Actions:

- Determine whether personal data is involved and assess notification obligations.
- Ensure supplier's notification meets contractual requirements.
- Provide guidance on regulatory/customer comms as required by internal policy. Outputs:
- Privacy impact assessment summary and required actions.

Step 6 — Technical reassessment (control posture)

Owner: SEA

Actions:

- Reassess supplier against minimum requirements with incident lens:
 - IAM and privileged access
 - logging/auditability
 - vulnerability management
 - incident response maturity and notification performance

- sub-processor transparency
- resilience (if outage involved)
- Identify new gaps; classify as “renewal blockers” or “conditions” as appropriate. Outputs:
- Updated gap log + remediation plan requirements.

Step 7 — Decision and escalation

Owner: Third-Party Security Program Owner + Business Service Owner

Actions:

- Determine recommended posture:
 - Continue (no material impact; controls adequate)
 - Continue with conditions (remediation required; enhanced monitoring)
 - Restrict scope (remove privileged access, disable write APIs, isolate environments)
 - Suspend service pending remediation
 - Offboarding planning (replace supplier)
- Escalate per governance for:
 - Critical suppliers with material impact
 - any residual risk acceptance required Outputs:
- Decision record with owners, due dates, and approval evidence.

Step 8 — Follow-up, closure, and lessons learned

Owner: Third-Party Security Program Owner + SEA

Actions:

- Track remediation actions to closure; validate evidence.
- Review supplier final RCA and confirm controls improved.
- Update exceptions (close/renew/raise) with expiry dates.
- Update metrics: incident count, notification SLA, impact severity, remediation cycle time.
Outputs:
- Review closed with closure evidence and updated supplier assurance status.

8. Mandatory artifacts to capture

- Supplier notification and updates (verbatim)
- Containment actions log
- Access/key rotation evidence (as applicable)
- Updated scope statement and tier confirmation
- Gap log and remediation plan
- Exception record(s) if MUST requirements are impacted
- Decision record and approvals
- Final RCA (when available) and lessons learned summary

9. Minimum communication expectations (supplier)

For Critical suppliers, supplier MUST provide:

- initial notification within contractual timeframe
- daily updates (or agreed cadence) during active incident
- final RCA with corrective actions and dates

10. Exit criteria (when the review can be closed)

Close when:

- impact is understood and documented,
- containment actions are complete or consciously maintained,
- required notifications/assessments (privacy/legal) are completed,
- remediation actions are agreed with owners and timelines,
- supplier assurance status is updated (approved/conditional/restricted).